

How Secure Is Your Base? A Recent Multi-Scanner Census of Linux Operating-System Images on Docker Hub

Anonymous

¹Anonymous Institution

Abstract. Every container starts from an operating-system (OS) base image, yet the security posture of these foundational images is usually measured with a single scanner and on samples that age quickly. We present a recent, multi-scanner census of the OS base images on Docker Hub: the **5,606** unique `amd64` images across the **21** repositories of Docker Hub’s Operating systems category, scanned with **14** independent open-source scanners spanning vulnerabilities, SBOM, misconfiguration, secrets and malware. Over the images processed to date we find that (i) vulnerability posture varies by an order of magnitude across distributions, with Debian and the RHEL family carrying the most critical and high findings and minimal or rolling-release distributions the fewest; (ii) staler images carry more vulnerabilities (Spearman $\rho = 0.16$, $p < 0.001$; bucketed means rising from ≈ 255 to ≈ 692); (iii) the four package-vulnerability engines barely agree (pairwise Jaccard ≤ 0.30), with OSV-Scanner and Clair nearly disjoint from the rest; and (iv) about one in five historically-published OS images can no longer be pulled by a modern Docker because they use a legacy manifest schema. We release the pipeline and the consolidated multi-scanner dataset, to our knowledge the first OS-base-focused one, on acceptance.

1. Introduction

Containers are now a default unit of software delivery: Docker reports more than 20 million developers using its tools and, in its 2025 survey, 92% of IT professionals using containers [Docker, Inc. 2025], while the Cloud Native Computing Foundation finds most organisations running the majority of their applications in containers [Cloud Native Computing Foundation 2025]. Underneath them sits Docker Hub, the largest public registry, with on the order of 8.3 million image repositories and hundreds of billions of cumulative pulls [Docker, Inc. 2024]. Every one of those images ultimately begins with a single line, FROM an operating-system (OS) base image, and a handful of bases are the common root of nearly all of them: `alpine`, `ubuntu`, `debian` and `busybox` each record more than a billion pulls, and Debian, Alpine and Ubuntu dominate the base-image choice of the ecosystem [Anchore 2024]. Because a flaw in a base image is inherited, unchanged, by every image built on it [Shu et al. 2017], the security posture of these few OS bases is a property the whole ecosystem inherits.

That inherited posture is poor and consequential. Software-supply-chain attacks are projected to cost USD 60 billion in 2025 [Cybersecurity Ventures 2023] and Gartner predicted that 45% of organisations would suffer such an attack by 2025 [Gartner, Inc. 2021]; meanwhile popular Docker Hub images carry hundreds of known vulnerabilities on average, many of them years old [NetRise 2024], against a backdrop of record CVE disclosure (46,407 CVEs in 2025, about 127 per day) [NIST National Vulnerability Database 2025]. Worse, some of the most-pulled OS bases are no longer maintained (every official `centos` tag reached end-of-life in June 2024) yet remain in heavy use.

Despite this central role, the security posture of OS base images has usually been characterised with a *single* scanner and on samples that age quickly: the large-scale Docker Hub measurements have typically used one detector [Shu et al. 2017, Zerouali et al. 2019, Liu et al. 2020, Shi et al. 2025], and the studies that *do* compare scanners have done so on focused samples [Kaur et al. 2021, Mills et al. 2023]. No recent work measures the Linux OS base images specifically, with a heterogeneous multi-scanner battery, as a current census. This paper fills that gap.

Contributions.

- A **recent multi-scanner census** of OS base images on Docker Hub: 14 scanners over 5,606 unique amd64 images of the 21 *Operating systems* repositories (Section 3).
- A **per-distribution security posture** and a measured **staleness-vulnerability** relationship (Sections 4.1, 4.2).
- A **four-engine divergence** measurement on the OS-package layer, including Clair, showing the chosen scanner dominates the reported posture (Section 4.3).
- A supply-chain **longevity finding**: a large share of historically-pulled OS images are no longer installable by a modern Docker (legacy manifest schema), and end-of-life bases remain heavily pulled.
- A **released artifact and dataset**. We release the scan pipeline and the consolidated multi-scanner dataset, the per-image reports of all 14 scanners over the OS census; to our knowledge it is the first OS-base-focused multi-scanner dataset, letting the measurement be audited, reproduced and extended (released on acceptance).

2. Related Work

Large-scale Docker Hub and base-image measurements. A rich line of work has charted the security of Docker Hub. [Shu et al. 2017] introduced the first large-scale study, scanning 356,218 images and showing that vulnerabilities propagate from a base image to everything built on it. [Liu et al. 2020] extended the scale to 2.2 million images; [Zerouali et al. 2019] introduced the notion of *technical lag* on 7,380 Debian-based images, later generalised to a multi-dimensional analysis over 140,000 images [Zerouali et al. 2021]. [Wist et al. 2021] analysed 2,500 images across image classes, [Ibrahim et al. 2020] examined how images for the same system differ across base distributions, and the recent [Shi et al. 2025] ranked influential images by pull count at the scale of the full registry. Most relevant to us, [Haque and Babar 2022] characterised the exploitability and impact of vulnerabilities in 261 official base images and reported a result we revisit in Section 4.5: highly-exploitable vulnerabilities are *more* frequent in minimal images such as Alpine, while larger distributions carry the higher-impact ones. These studies established the prevalence and propagation of vulnerabilities in the ecosystem; each draws on a single vulnerability detector, and our multi-scanner design complements them by also quantifying how much the measured posture depends on the chosen scanner.

Inter-scanner divergence. A second line studies how much a scan result depends on the tool used. [Imtiaz et al. 2021] compared nine software-composition-analysis tools on the same projects and found counts spanning an order of magnitude, and [Javed and Toor

2021a, Javed and Toor 2021b] report comparable variation among container scanners. For containers, careful side-by-side comparisons have been conducted on focused samples: [Kaur et al. 2021] use four scanners over 44 images, [Mills et al. 2023] six over 380, and the recent [Churakova et al. 2026] evaluate seven scanner and VEX tools on 48 images, finding counts from 191 to 18,680 and a best-pair (Trivy and Grype) agreement of about 69%. On the OS-package layer specifically, [Bufalino et al. 2025] report that current scanners are largely incompatible because of package-identifier mismatches, and [Zhou et al. 2026, Rosso et al. 2026] document high false-positive rates and silent tool failures in SBOM-based scanning. Our work is complementary, bringing this multi-scanner lens to the OS-base layer at census scale, adding Clair, and relating the divergence to image age and distribution.

Gap. Building on this body of work, we are not aware of a recent study that measures the Linux OS base images of Docker Hub specifically with a heterogeneous multi-scanner battery as a current census, nor one that quantifies the prevalence and popularity of *end-of-life* OS images that remain in heavy use. This paper addresses both.

Table 1. Positioning against prior OS/base-image measurements.

Work	Year	Images	Scanners	Dims.	OS-focused	Cross-scanner
[Shu et al. 2017]	2017	356,218	1	V	✗	✗
[Zerouali et al. 2019]	2019	7,380	1	V	✓ (Debian)	✗
[Kaur et al. 2021]	2021	44	4	V	✗	✓
[Mills et al. 2023]	2023	380	6	V	✗	✓
[Haque and Babar 2022]	2022	261	1	V	✓	✗
[Shi et al. 2025]	2025	33,952	1	V,S,C,M	✗	✗
[Churakova et al. 2026]	2026	48	7	V	✗	✓
This work	2026	5,606	14	V,B,S,C,M	✓	✓

Dims.: V vuln, B SBOM, S secrets, C config, M malware.

3. Methodology

Corpus. We take as our corpus the operating-system base images that Docker Hub itself lists under its *Operating systems* category: 22 repositories (e.g. alpine, ubuntu, debian, centos, busybox, amazonlinux, fedora, oraclelinux, rockylinux, almalinux, photon, opensuse, archlinux, kali), one of which (clefos) publishes no linux/amd64 image and drops out. Using the Docker Hub API we enumerated *all* tags of these repositories, **6,328** tags in total, of which **6,138** carry an amd64/linux image. We note in passing that the “10K+” tag badge Docker Hub shows for ubuntu and alpine counts tag × architecture × attestation manifests, not distinct tags: ubuntu has 725 distinct tags and debian 2,884. Because many tags point to a byte-identical image (e.g. 24.04, noble and latest), we deduplicate by amd64 content digest, leaving **5,606** unique images, the unit of measurement throughout.

Scanner battery. An OS base image is a static root filesystem with no application source code and no running service, so we select the static-analysis axes that apply to

such an artifact and run 14 open-source scanners.¹ *SBOM*: Syft and cdxgen. *Package vulnerabilities (SCA)*: Trivy, Grype, OSV-Scanner and Clair. *Image hardening*: Dockle and Checkov. *Secrets*: TruffleHog, Gitleaks, detect-secrets and Whispers. *Malware/IOC*: ClamAV and YARAHunter. We deliberately exclude the SAST, dynamic (DAST) and network axes, which require application source or a running service that a base image does not provide; we make this selection explicit so the battery matches the artifact under study.

Harness and scan order. Each image is pulled *pinned by its amd64 digest*, exported once to a local tar archive, and analysed by all 14 scanners reading that archive; the image is removed afterwards to bound disk. Every scanner runs in its own Docker container and a per-scanner adapter normalises the raw output to a common Finding schema; raw outputs are kept verbatim. To obtain a balanced partial dataset at any stopping point, the scan queue is ordered *round-robin* across the 21 repositories, and within each repository it alternates newest $\leftrightarrow$ oldest by last-push date, so the full age range of every distribution is covered early.

4. Results

The census is still running; the figures and numbers below are computed over the **1,927** images scanned so far and are regenerated as it completes.

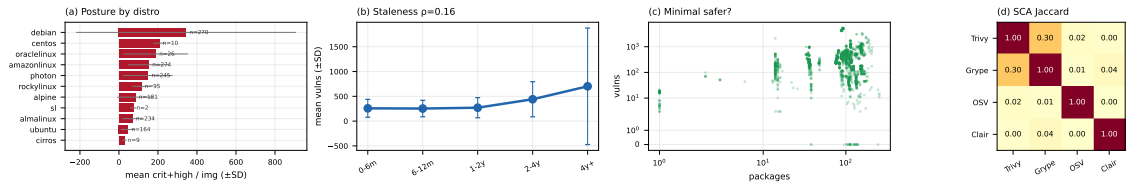


Figure 1. Posture by distribution (a), staleness (b), packages vs. vulnerabilities (c), SCA-engine Jaccard (d). Bars: ± 1 SD.

4.1. RQ1: Security posture by distribution

Critical- and high-severity vulnerability findings vary by an order of magnitude across distributions (Figure 1(a)). Debian carries the most (mean ≈ 344 critical+high per image, $n = 270$), followed by the RHEL family (CentOS ≈ 206 , OracleLinux ≈ 189 , AmazonLinux ≈ 152 , RockyLinux ≈ 115); Alpine sits lower (≈ 84), and Arch, ALT, Kali, Mageia and openSUSE Tumbleweed report few or none. Within-distribution variance is large (for Debian the standard deviation, ≈ 564 , exceeds the mean), so these are population tendencies rather than tight estimates, and the smaller repositories (for example CentOS, $n = 10$) should be read with care. Package count does not track this ordering: Mageia and Fedora carry many packages yet few critical or high findings, a point we return to in Section 4.5.

4.2. RQ2: Staleness vs. vulnerability

Vulnerability count tends to rise with image age (Figure 1(b)). Images rebuilt within the last six months carry a mean of ≈ 255 total vulnerability findings, climbing through

¹Each scanner runs from a version-pinned container image; the exact versions are recorded in the released configuration.

≈ 273 (one to two years) and ≈ 457 (two to four years) to ≈ 692 for images not rebuilt in over four years. At the image level the rank correlation between age and vulnerability count is positive and significant, though modest (Spearman $\rho = 0.16$, $p < 0.001$, $n = 1,927$), reflecting wide within-bucket variance; the bucketed means themselves increase monotonically. This reproduces the technical-lag effect of [Zerouali et al. 2019] on the OS-base subset and across 21 distributions at once.

4.3. RQ3: Inter-scanner divergence on OS packages

The four package-vulnerability engines barely agree (Figure 1). Over (image, CVE, package) triples the best-agreeing pair is Trivy and Gripe, at a Jaccard of **0.30**; every other pair is below 0.05, and OSV-Scanner and Clair are essentially disjoint from the rest ($\text{OSV} \cap \text{Clair} = 0$). The engines differ in scope: Gripe and Trivy report the most triples (353k and 227k), OSV-Scanner targets language-ecosystem advisories (96k), and Clair maps only specific distributions to its feeds (43k, and zero on Rocky and AlmaLinux, which it does not map to the RHEL feeds). The reported security posture of an OS image is thus, to a large degree, a property of the chosen scanner, echoing [Churakova et al. 2026] at far larger scale and on the OS layer specifically.

4.4. RQ4: End-of-life and un-pullable images

Two longevity hazards surface. First, about **20%** of the digest-pinned OS images fail to pull on a current Docker Engine with `manifest schema unsupported`: they are old images in the deprecated Docker image-manifest schema 1, whose support modern Docker removed. The digests still exist on Docker Hub, but the images are no longer installable, a hazard concentrated in the oldest tags (highest for `ubuntu`, near zero for `archlinux` and `almalinux`). Second, end-of-life distributions remain in heavy use: every `centos` tag has been unmaintained since June 2024, yet the repository still records over a billion pulls. To our knowledge neither the prevalence of legacy-schema OS images nor the popularity of EOL bases has been measured before.

4.5. RQ5: Is a minimal image safer?

The intuition that a smaller image is a safer one does not hold cleanly (Figure 1(c)). The relationship between package count and vulnerability count is not monotonic: BusyBox, with a single package, carries only a handful of findings, but Mageia, with around 250 packages, carries about a dozen, while Debian carries hundreds of critical and high findings with fewer packages than Mageia. This refines [Haque and Babar 2022]: on our multi-scanner data the vulnerability count is governed more by a distribution’s advisory coverage and patch cadence than by image size.

4.6. Reproducing prior analyses

Our four questions reproduce, on the OS-base subset specifically, concrete analyses from prior work (Table 2); the direction holds in every case, and the multi-scanner setting lets us refine the minimal-image and scanner-agreement results that single-tool studies could not.

Table 2. Prior analyses reproduced on our OS-base corpus.

Study	Analysis reproduced	As originally reported	On our corpus (14 scanners)
[Shu et al. 2017]	worst-severity class and per-image vulnerability counts	>80% of images with a high-severity flaw; over 180 vulnerabilities per image on average	critical and high findings near-universal; Debian carries a mean of ≈ 344 critical+high per image (RQ1)
[Zerouali et al. 2019, Zerouali et al. 2021]	technical lag: image age vs vulnerabilities (Debian)	no release free of vulnerabilities; lag grows with age	total findings rise monotonically from ≈ 255 (under 6 months) to ≈ 692 (over 4 years), across all 21 distributions (RQ2)
[Ibrahim et al. 2020]	how images for the same system differ across base distributions	posture varies markedly with the chosen base	per-distribution critical+high spans an order of magnitude: Debian and the RHEL family high, Alpine low (RQ1)
[Haque and Babar 2022]	minimal vs large base images	minimal images are not safer (carry more highly-exploitable CVEs)	vulnerability count is non-monotonic in package count (BusyBox, 1 package, versus Mageia, ≈ 250) (RQ5)
[Churakova et al. 2026]	agreement among container scanners (48 images)	best pair (Trivy/Grype) Jaccard 0.69; all tools near 0%	Trivy/Grype Jaccard 0.30 over (image, CVE, package) on 5.6k OS images; OSV and Clair near-disjoint (RQ3)

4.7. Threats to validity

Several threats bound these results. *Coverage*: the census is still running, so the numbers reflect the 1,927 images processed to date; the round-robin order keeps every distribution represented, but the smaller repositories carry wide uncertainty and their means may shift as the run completes. *Scanner error*: we report raw scanner output and do not adjudicate false positives or negatives, and the divergence we measure (RQ3) itself implies that no single engine is ground truth; severity, moreover, rests on CVSS scores that can overstate operational risk without VEX or reachability information [Zhou et al. 2026]. *Architecture*: we scan `linux/amd64` only, so the findings may not transfer to `arm64`. *Temporal drift*: a tag can be re-pushed during the census, so each image is characterised as of its scan time. *Generality*: the corpus is Docker Hub’s *Operating systems* category, so other registries (Quay, GHCR) and non-base images are out of scope. The released dataset lets others re-run the analysis under different choices.

5. Conclusion

We presented a recent, multi-scanner census of the operating-system base images of Docker Hub, the bases on which nearly every container is built, scanned with 14 independent open-source tools rather than one. Across the images measured so far, vulnerability posture varies by an order of magnitude across distributions and rises steadily with image age; the four package-vulnerability engines agree on almost nothing, so the posture a single tool reports is in large part a property of that tool; a smaller image is not reliably a safer one; and about a fifth of historically-published OS images can no longer be installed by a modern Docker, while end-of-life bases such as CentOS remain heavily pulled. We release the pipeline and the consolidated dataset² so the measurement can be reproduced and kept current.

References

- Anchore (2024). A breakdown of the operating systems of docker hub. <https://anchore.com/blog/breakdown-of-operating-systems-of-dockerhub/>.
- Bufalino, J., Di Francesco, M., Blaise, A., and Secci, S. (2025). SBOMproof: Beyond alleged SBOM compliance for supply chain security of container images.
- Churakova, Y., Ekstedt, M., and Schmid, L. (2026). Vexed by VEX tools: Consistency evaluation of container vulnerability scanners. *arXiv preprint arXiv:2503.14388*. version 3.
- Cloud Native Computing Foundation (2025). CNCF annual survey 2024. <https://www.cncf.io/reports/cncf-annual-survey-2024/>. Accessed: May 2026.
- Cybersecurity Ventures (2023). Software supply chain attacks to cost the world \$60 billion by 2025. <https://cybersecurityventures.com/software-supply-chain-attacks-to-cost-the-world-60-billion-by-2025/>. Accessed: May 2026.
- Docker, Inc. (2024). Docker index: Continued massive developer adoption and activity. <https://www.docker.com/blog/docker-index-shows-continued-massive-developer-adoption-and-activity-to-build-and-share-apps-with-docker/>. Docker Hub: 8.3M image repositories, 318B cumulative pulls, 7.3M accounts.

²The scan pipeline, analysis code and the consolidated multi-scanner dataset will be released on acceptance.

- Docker, Inc. (2025). The 2025 Docker state of application development report. <https://www.docker.com/blog/2025-docker-state-of-app-dev/>. Accessed: May 2026.
- Gartner, Inc. (2021). Gartner predicts 45% of organizations worldwide will have experienced attacks on their software supply chains by 2025. Gartner Press Release. Accessed: May 2026.
- Haque, M. U. and Babar, M. A. (2022). Well begun is half done: An empirical study of exploitability and impact of base-image vulnerabilities. In *2022 IEEE Intl. Conf. on Software Analysis, Evolution and Reengineering (SANER)*, pages 1100–1111. IEEE.
- Ibrahim, M. H., Sayagh, M., and Hassan, A. E. (2020). Too many images on DockerHub! how different are images for the same system? *Empirical Software Engineering*, 25(5):4250–4281.
- Imtiaz, N. et al. (2021). A comparative study of vulnerability reporting by software composition analysis tools. In *Proceedings of the 15th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*.
- Javed, O. and Toor, S. (2021a). An evaluation of container security vulnerability detection tools. In *Proc. 2021 5th Intl. Conf. on Cloud and Big Data Computing (ICCBDC)*, pages 95–101. ACM.
- Javed, O. and Toor, S. (2021b). Understanding the quality of container security vulnerability detection tools. *arXiv preprint arXiv:2101.03844*.
- Kaur, B., Dugré, M., Hanna, A., and Glatard, T. (2021). An analysis of security vulnerabilities in container images for scientific data analysis. *GigaScience*, 10(6):giab025.
- Liu, P., Ji, S., Fu, L., Lu, K., Zhang, X., Lee, W.-H., Lu, T., Chen, W., and Beyah, R. (2020). Understanding the security risks of Docker Hub. In *Computer Security – ESORICS 2020*, volume 12308 of *Lecture Notes in Computer Science*, pages 257–276. Springer.
- Mills, A., White, J., and Legg, P. (2023). Longitudinal risk-based security assessment of docker software container images. *Computers & Security*, 135:103478.
- NetRise (2024). Analysis of vulnerabilities in popular container images. Popular Docker Hub images average 604 known vulnerabilities, over 45% older than two years.
- NIST National Vulnerability Database (2025). Nvd dashboard: Cve publication statistics. <https://nvd.nist.gov/general/nvd-dashboard>. 46,407 CVEs published in 2025, about 127 per day; 263% growth 2020–2025.
- Rosso, M., Jaffar, M. A. J., Brighente, A., and Conti, M. (2026). A practical solution to systematically monitor inconsistencies in SBOM-based vulnerability scanners. In *Proc. 41st ACM/SIGAPP Symposium on Applied Computing (SAC '26)*. ACM.
- Shi, H., Ying, L., Chen, L., Duan, H., Liu, M., and Xue, Z. (2025). Dr. Docker: A large-scale security measurement of Docker image ecosystem. In *Proceedings of the ACM Web Conference 2025 (WWW '25)*. ACM.
- Shu, R., Gu, X., and Enck, W. (2017). A study of security vulnerabilities on Docker Hub. In *Proceedings of the Seventh ACM Conference on Data and Application Security and Privacy (CODASPY '17)*, pages 269–280. ACM.
- Wist, K., Helsem, M., and Gligoroski, D. (2021). Vulnerability analysis of 2500 Docker Hub images. In *Advances in Security, Networks, and Internet of Things*, Transactions on Computational Science and Computational Intelligence, pages 307–327. Springer.
- Zerouali, A., Mens, T., Decan, A., Gonzalez-Barahona, J., and Robles, G. (2021). A multi-dimensional analysis of technical lag in Debian-based Docker images. *Empirical Software Engineering*, 26(2):19.

- Zerouali, A., Mens, T., Robles, G., and Gonzalez-Barahona, J. M. (2019). On the relation between outdated Docker containers, severity vulnerabilities, and bugs. In *Proceedings of the IEEE 26th International Conference on Software Analysis, Evolution and Reengineering (SANER 2019)*, pages 491–501. IEEE.
- Zhou, L., Dacier, M., and Konstantinou, C. (2026). A reality check on SBOM-based vulnerability management: An empirical study and a path forward. In *Proc. 16th ACM Conf. on Data and Application Security and Privacy (CODASPY '26)*. ACM.